

Overall Conclusion: Cybersecurity Penetration Testing Journey

Completing this cybersecurity penetration testing assessment gave me practical hands-on experience in testing web applications and capturing flags. Before starting this assessment, I had theoretical knowledge about security vulnerabilities, but completing the four practical tasks helped me understand how testing works in real situations. I learned that penetration testing is not just about entering commands or copying payloads. It is about understanding how the application functions, establishing normal behaviour, testing inputs step by step, observing the responses, and troubleshooting when something does not work as expected.

What I Learned

One of the most important lessons I learned was the value of establishing normal application behaviour before testing for vulnerabilities. For example, during Flag 3 (Command Injection), the initial IP addresses I tested did not return a working connection. Instead of guessing randomly, testing 127.0.0.1 gave a successful connection, which established a working baseline and showed that the application was processing the input. Similarly, in Flag 4 (Unrestricted File Upload), uploading a normal image first helped me see how a valid file was processed before I attempted to test an executable PHP file.

I also learned how different vulnerabilities work through practical testing. In Flag 1 (SQL Injection), I learned how to determine the number of columns in an SQL query by testing column positions step by step. When testing the login feature, the query worked up to column 6 and gave an error at column 7. Later, when testing the profile section, the query worked up to column 9 and gave an error at column 10. This showed me that different features in the same application can use different database queries, and that I need to carefully analyse server responses before deciding my next step.

In Flag 2 (IDOR), I learned how Insecure Direct Object References work when access control is missing. By modifying the object ID parameter and checking different records, I found the flag at ID 5. This showed me how easily unauthorised data can be exposed if the server does not verify user authorization.

Through Flag 3 and Flag 4, I learned how unsafe input handling can lead to command execution on the operating system. In Flag 4, I used Burp Suite to intercept and modify the HTTP request to bypass client-side checks and upload a PHP file. I also learned that gaining command execution does not mean the task is finished. After getting command execution, I still had to explore the system using commands like `whoami` and `pwd`, list directories, search the filesystem for flag files, and read the final flag.

Finally, I learned the importance of proper documentation. Collecting evidence such as screenshots, requests, responses, and commands helped me prove what happened at each step. I learned that a penetration testing report must clearly explain the action taken, the reason for the test, the observations, the security impact, and practical remediation recommendations.

Was the Journey Difficult?

The journey was challenging at times, but not every task was difficult. The four flags had different difficulty levels based on the testing required.

Flag 2 (IDOR) was the easiest task for me. I did not face any major difficulty because modifying the ID parameter to 5 allowed me to find the flag straightforwardly. However, the other three flags required more effort and troubleshooting.

Flag 1 was difficult because I had to work through the SQL Injection testing step by step and understand the database error responses to determine column counts. Flag 3 had an initial problem where the provided IP addresses did not work, and I had to discover that 127.0.0.1 produced a working baseline before testing command injection. Flag 4 was also difficult because I had to use Burp Suite to inspect the upload request and troubleshoot PHP execution errors before getting command execution to work.

The biggest difficulty overall was figuring out what to do next when a test did not produce the expected result on the first attempt. Working through these issues required patience and repeated testing. This taught me that a failed test does not mean a vulnerability is absent; it often means I need to understand the application better and test the input in a different way.

What I Need to Improve

As a student who is still learning cybersecurity, this assessment helped me identify several areas where I need to improve:

First, I need to improve my Linux fundamentals and filesystem knowledge. Becoming more familiar with Linux navigation, file permissions, and search commands will help me investigate systems more efficiently.

Second, I need to strengthen my SQL and database knowledge so that I can better understand complex database queries and interpret errors during SQL Injection testing.

Third, I need to improve my understanding of web applications and HTTP requests, especially how data is transmitted between the browser and backend server. I also want to become more proficient with Burp Suite features beyond basic request interception.

Fourth, I want to learn programming and scripting in Python or Bash. This will help me understand application code better and automate repetitive testing steps.

Finally, I need to focus on understanding why a vulnerability works rather than only memorising commands or payloads, while continuing to improve my technical report writing skills.

Final Reflection

Overall, this penetration testing assessment has been a very valuable practical learning experience. It taught me that penetration testing requires patience, careful observation, understanding the reason behind each test, and learning from failed attempts. I am still learning cybersecurity, and this assessment has provided me with a solid foundation. Moving forward, I plan to continue practicing in security labs, improving my technical skills, and developing my knowledge step by step.

Assessment Repository

GitHub

Assessment

Repository:

<https://github.com/sudip12302/Cybersecurity/tree/main/Assessment>